VULNERABILITY TESTING / LAB REPORT

OWASP JUICE SHOP

Web Application Penetration Testing – Internship Report

Organization: IqraSec Academy
Platform: TryHackMe

COVER PAGE

Field	Details
Intern Name	Rohit Kushwah
Organization	IqraSec Academy
Internship	Web Application Penetration Testing (WAPT)
Topic	OWASP Juice Shop – Web Application Security Testing
Platform	TryHackMe
Number of Labs	1
Completion Date	25 October 2026

This report documents the objective, vulnerability concepts, testing methodology, evidence, impact, remediation, and learning outcomes of the OWASP Juice Shop lab.

Lab 1: OWASP Juice Shop

1. Lab Name

OWASP Juice Shop

Platform: TryHackMe
Room URL: https://tryhackme.com/room/owaspjuiceshop

2. Objective

The objective of this lab is to practice web application security testing in an intentionally vulnerable training application and understand common security weaknesses that may affect real-world applications.

The main objectives are:

- Understand common web application vulnerabilities.
- Review authentication and access control weaknesses.
- Understand injection vulnerabilities and insecure input handling.
- Examine security misconfigurations and sensitive information exposure.
- Learn to identify and document security findings.
- Understand the impact of vulnerabilities on confidentiality, integrity, and availability.
- Recommend appropriate remediation techniques.

3. Vulnerability / Concept

What is OWASP Juice Shop?

OWASP Juice Shop is an intentionally vulnerable web application designed for security training. It provides a practical environment for learning about common web application weaknesses and practicing security testing.

Common Vulnerability Categories

1. Injection

Injection vulnerabilities occur when untrusted input is interpreted as part of a command or query instead of being handled as data.

Examples include SQL injection and operating-system command injection.

2. Broken Authentication

Authentication weaknesses can allow unauthorized users to access accounts or undermine the application's identity verification mechanisms.

3. Broken Access Control

Broken access control occurs when an application fails to enforce permissions correctly, allowing users to access resources or perform actions beyond their authorization.

4. Cross-Site Scripting (XSS)

XSS occurs when an application handles untrusted content unsafely and causes it to execute as script in another user's browser.

5. Security Misconfiguration

Security misconfiguration includes insecure application settings, unnecessary exposed functionality, and inappropriate default configurations.

6. Sensitive Data Exposure

Sensitive information may be disclosed when applications fail to protect confidential data or expose it through responses, files, or configuration.

7. Insecure File Handling

Applications may be vulnerable when file uploads, file paths, or file access permissions are not adequately validated and restricted.

8. Vulnerable Components

Outdated or vulnerable libraries and dependencies can introduce weaknesses into an otherwise secure application.

These are general web application security concepts. This report does not claim that each category was successfully demonstrated in the assigned room.

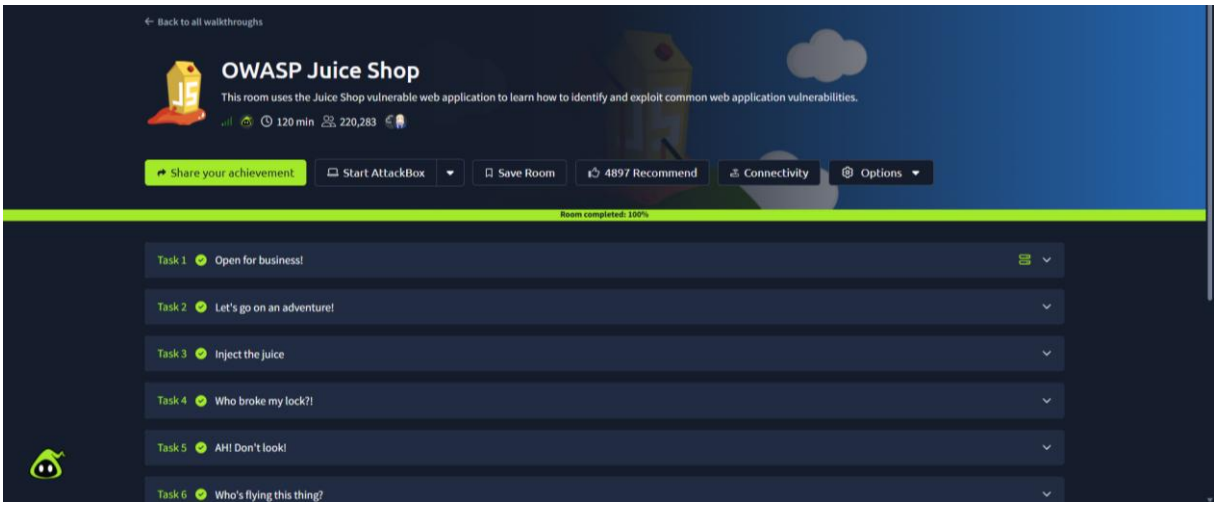
4. Testing Approach

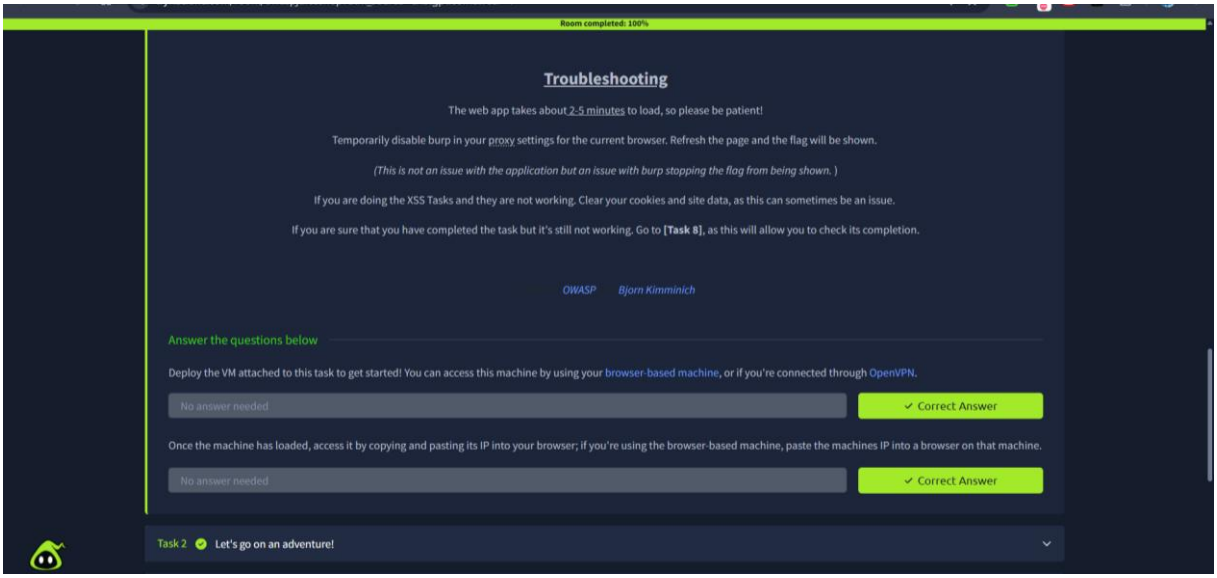
The following methodology can be used in the authorized TryHackMe training environment.

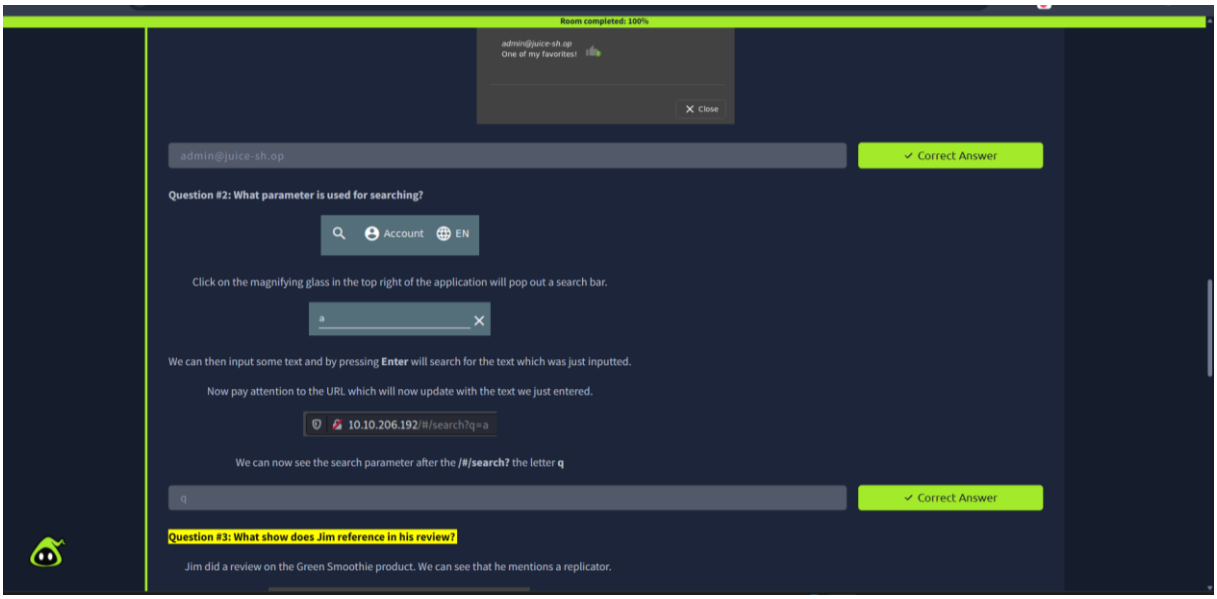
1. Open the OWASP Juice Shop room on TryHackMe.
2. Read the room instructions and understand the assigned objectives.
3. Start the provided lab environment if required.
4. Open the Juice Shop application using the supplied target URL.
5. Review the application's main pages and available functionality.
6. Identify authentication, account management, and access control features.
7. Observe how the application handles user input and displays responses.
8. Review relevant requests and responses using the browser's developer tools or an authorized intercepting proxy, if permitted by the lab.
9. Follow the room's instructions to examine its designated security challenges.
10. Review SQL injection concepts and test only the functionality specified by the exercise.
11. Review XSS concepts and examine how the application handles untrusted content.
12. Examine authorization behavior for resources and actions where the lab provides a suitable exercise.
13. Review file handling and input validation where relevant to the assigned tasks.
14. Observe error messages, application responses, and unexpected behavior.
15. Distinguish confirmed vulnerabilities from theoretical risks or ordinary application errors.
16. Record the requests, responses, and conditions associated with each confirmed finding.
17. Capture screenshots of the relevant tests and observed outcomes.
18. Assess the potential impact of each confirmed finding.
19. Recommend suitable remediation measures for the identified weaknesses.
20. Document the results and verify the actual completion status of the assigned lab.

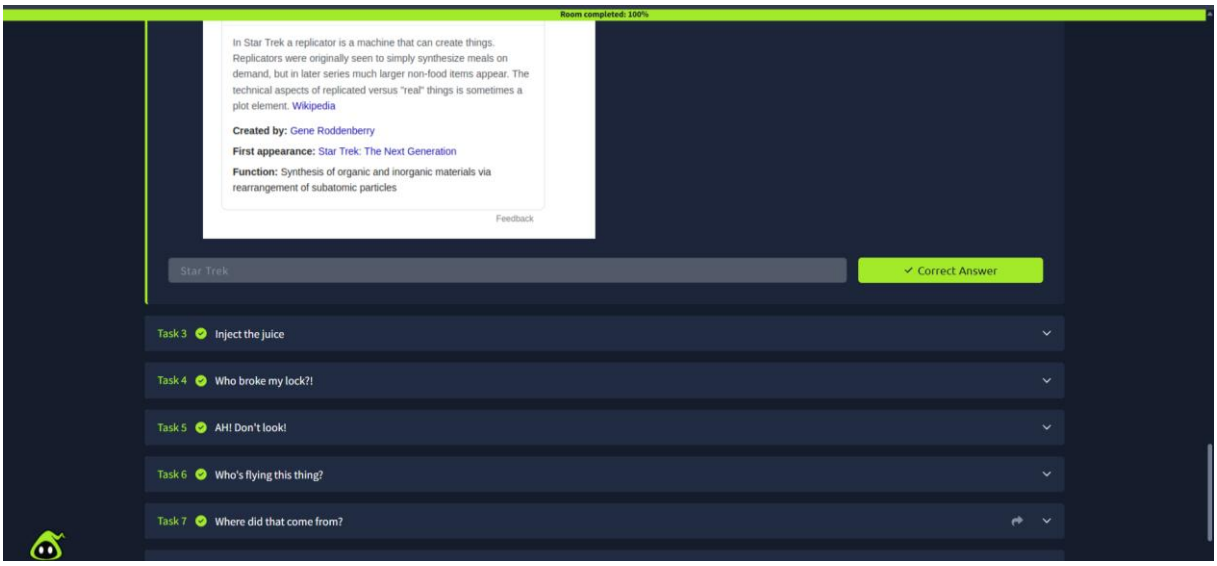
Testing note: OWASP Juice Shop contains many possible challenges. Perform only the exercises assigned or selected in your authorized training environment. Do not claim that every vulnerability category was tested or exploited unless supporting evidence exists.

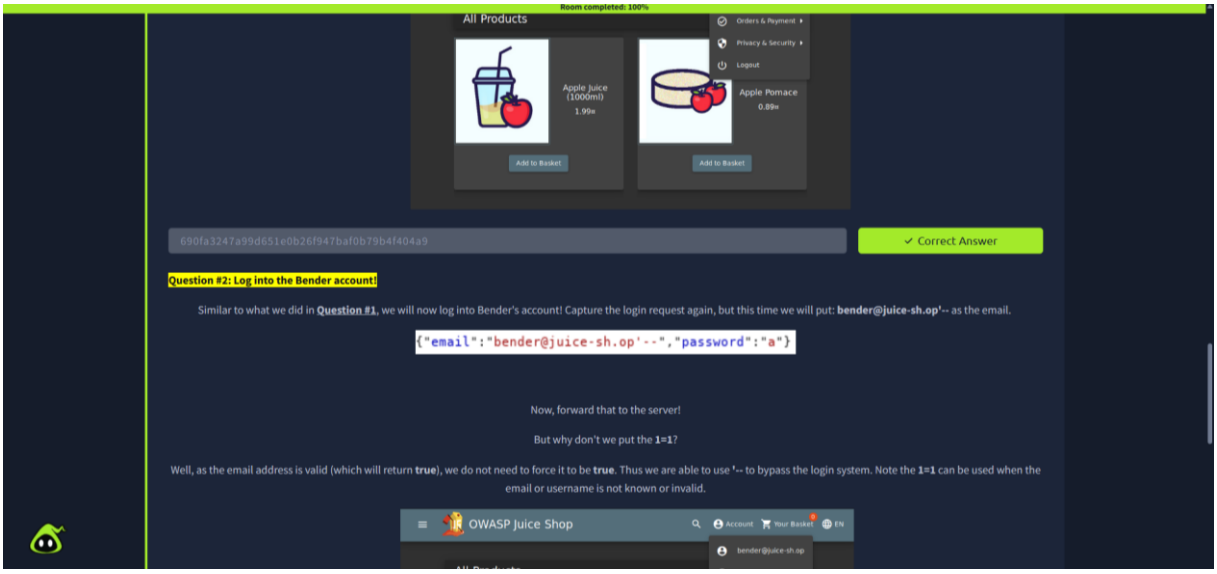
5. Evidence / Screenshots

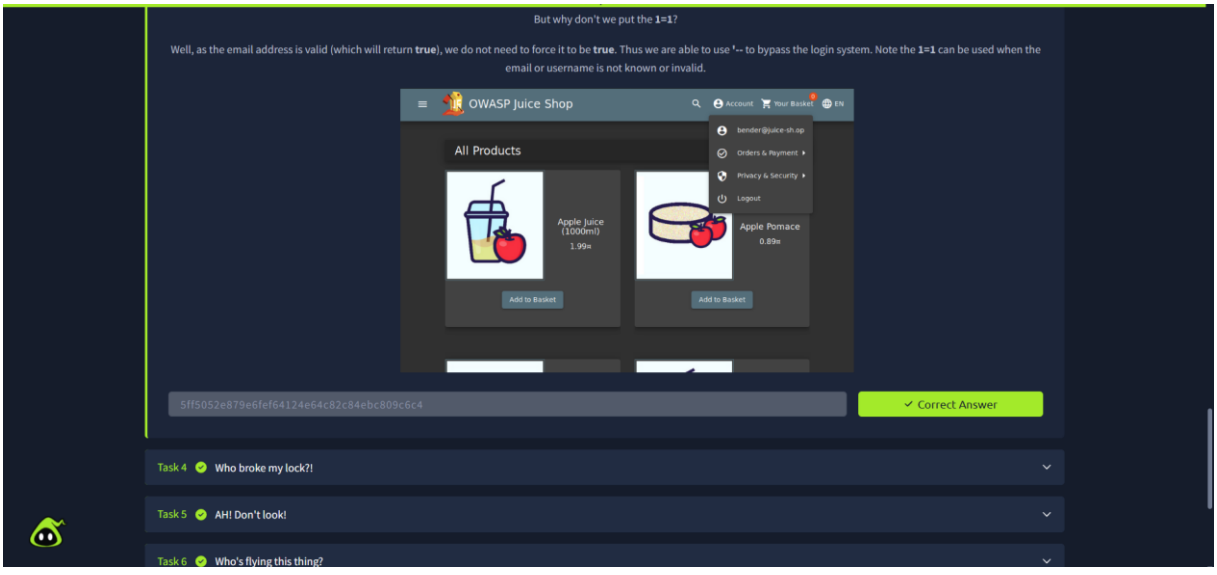

Back to all walkthroughs
OWASP Juice Shop
This room uses the Juice Shop vulnerable web application to learn how to identify and exploit common web application vulnerabilities.
120 min
220,283
Share your achievement
Start AttackBox
Save Room
4897 Recommend
Connectivity
Options
Room completed: 100%
Task 1 Open for business!
Task 2 Let's go on an adventure!
Task 3 Inject the juice
Task 4 Who broke my lock?!
Task 5 AH! Don't look!
Task 6 Who's flying this thing?

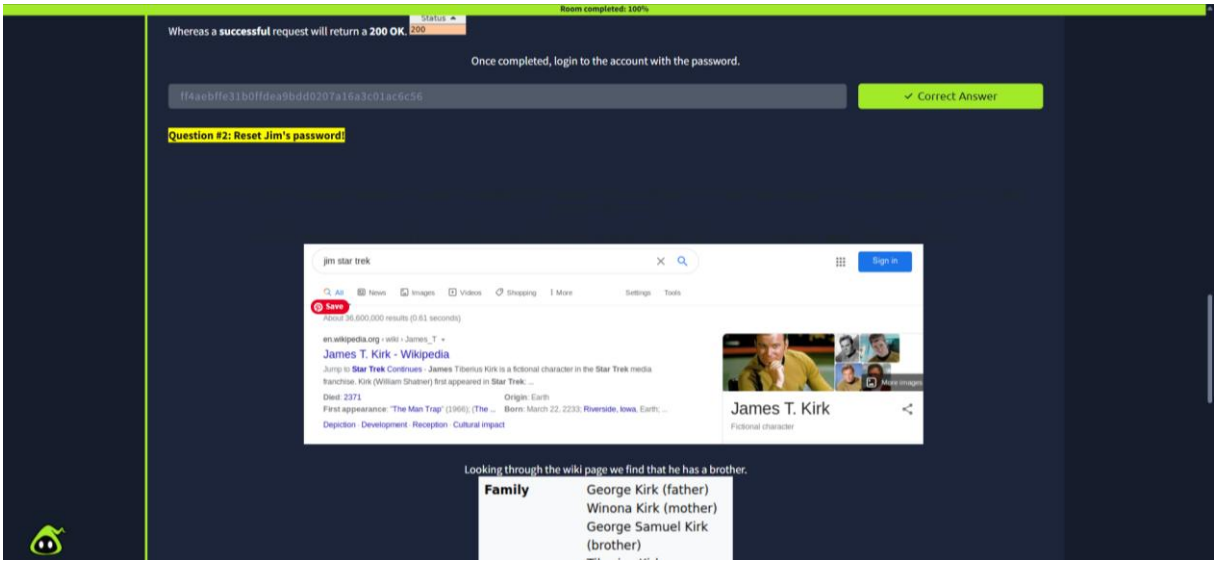

Room completed: 100%
Troubleshooting
The web app takes about 2-5 minutes to load, so please be patient!
Temporarily disable burp in your proxy settings for the current browser. Refresh the page and the flag will be shown.
(This is not an issue with the application but an issue with burp stopping the flag from being shown.)
If you are doing the XSS Tasks and they are not working. Clear your cookies and site data, as this can sometimes be an issue.
If you are sure that you have completed the task but it's still not working. Go to [Task 8], as this will allow you to check its completion.
OWASP Bjorn Kimminich
Answer the questions below
Deploy the VM attached to this task to get started! You can access this machine by using your browser-based machine, or if you're connected through OpenVPN.
No answer needed
Correct Answer
Once the machine has loaded, access it by copying and pasting its IP into your browser; if you're using the browser-based machine, paste the machines IP into a browser on that machine.
No answer needed
Correct Answer
Task 2 Let's go on an adventure!

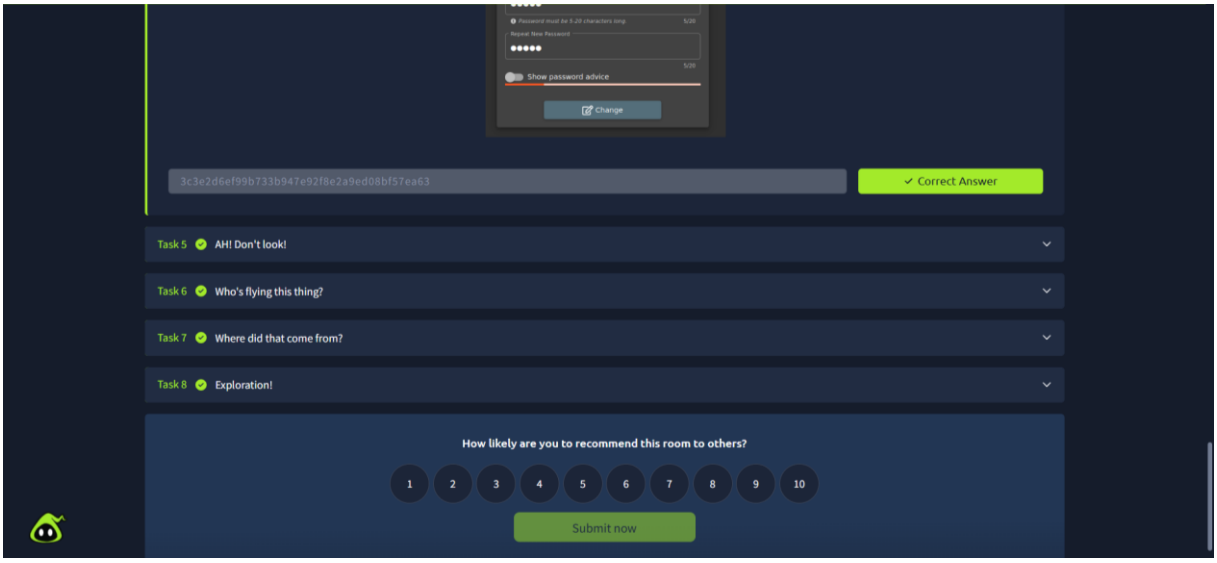

Room completed: 100%
admin@juice-sh.op
One of my favorites!
Close
admin@juice-sh.op
Correct Answer
Question #2: What parameter is used for searching?
Account
EN
Click on the magnifying glass in the top right of the application will pop out a search bar.
a
We can then input some text and by pressing Enter will search for the text which was just inputted.
Now pay attention to the URL which will now update with the text we just entered.
10.10.206.192/#/search?q=a
We can now see the search parameter after the /#/search? the letter q
q
Correct Answer
Question #3: What show does Jim reference in his review?
Jim did a review on the Green Smoothie product. We can see that he mentions a replicator.

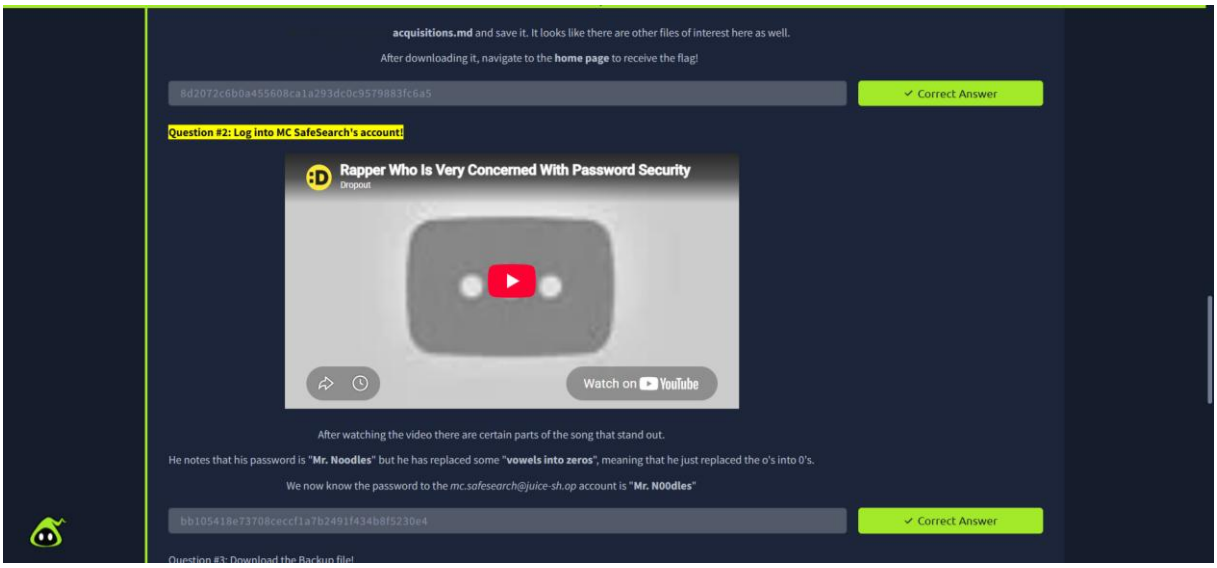

Room completed: 100%
In Star Trek a replicator is a machine that can create things. Replicators were originally seen to simply synthesize meals on demand, but in later series much larger non-food items appear. The technical aspects of replicated versus "real" things is sometimes a plot element. Wikipedia
Created by: Gene Roddenberry
First appearance: Star Trek: The Next Generation
Function: Synthesis of organic and inorganic materials via rearrangement of subatomic particles
Feedback
Star Trek
✓ Correct Answer
Task 3 Inject the juice
Task 4 Who broke my lock?!
Task 5 AH! Don't look!
Task 6 Who's flying this thing?
Task 7 Where did that come from?

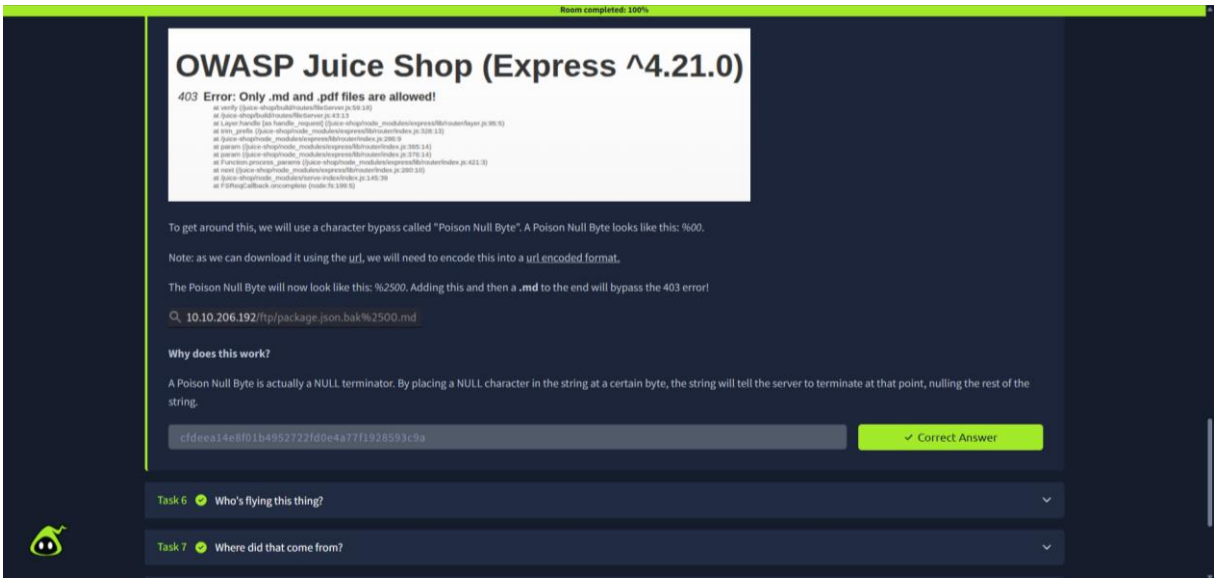

Room completed: 100%
All Products
Apple Juice (1000ml) 1.99¤
Apple Pomace 0.89¤
Add to Basket
690fa3247a99d651e0b26f947baf0b79b4f404a9
✓ Correct Answer
Question #2: Log into the Bender account!
Similar to what we did in Question #1, we will now log into Bender's account! Capture the login request again, but this time we will put: bender@juice-sh.op'-- as the email.
{"email":"bender@juice-sh.op'--","password":"a"}
Now, forward that to the server!
But why don't we put the 1=1?
Well, as the email address is valid (which will return true), we do not need to force it to be true. Thus we are able to use '-- to bypass the login system. Note the 1=1 can be used when the email or username is not known or invalid.
OWASP Juice Shop

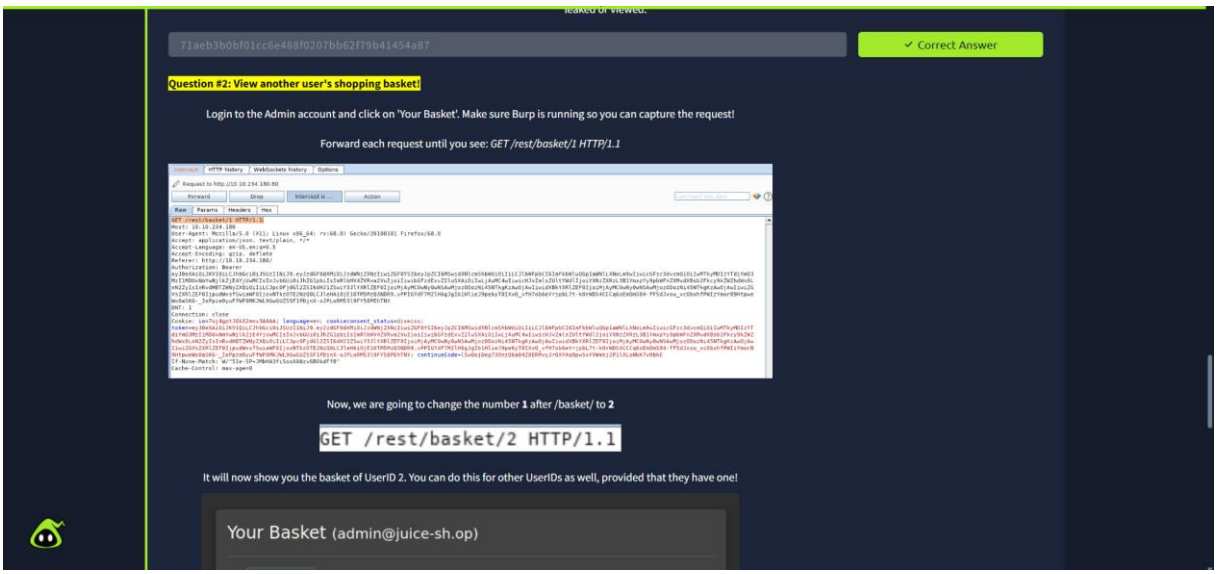

But why don't we put the 1=1?
Well, as the email address is valid (which will return true), we do not need to force it to be true. Thus we are able to use '-- to bypass the login system. Note the 1=1 can be used when the email or username is not known or invalid.
OWASP Juice Shop
All Products
Apple Juice (1000ml) 1.99¤
Apple Pomace 0.89¤
Add to Basket
5ff5052e879e6fef64124e64c82c84ebc809c6c4
✓ Correct Answer
Task 4 Who broke my lock?!
Task 5 AH! Don't look!
Task 6 Who's flying this thing?

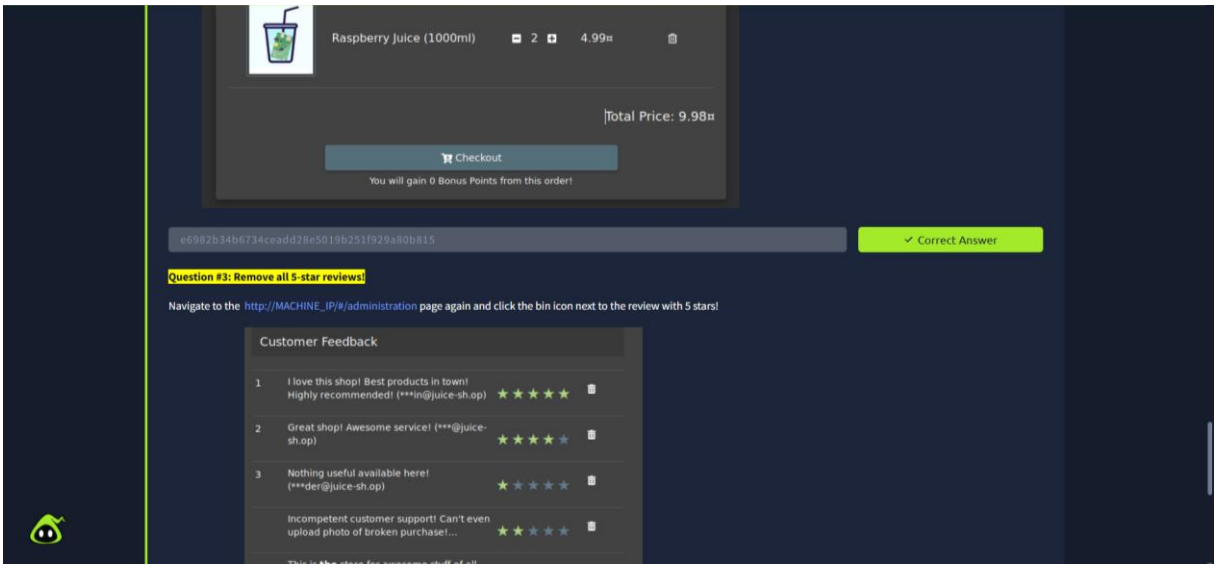

Room completed: 100%
Whereas a successful request will return a 200 OK.
Status
200
Once completed, login to the account with the password.
ff4aebffe31b0ffdea9bdd0207a16a3c01ac6c56
✓ Correct Answer
Question #2: Reset Jim's password!
jim star trek
Sign in
Save
James T. Kirk - Wikipedia
James T. Kirk
Fictional character
Looking through the wiki page we find that he has a brother.
Family
George Kirk (father)
Winona Kirk (mother)
George Samuel Kirk (brother)

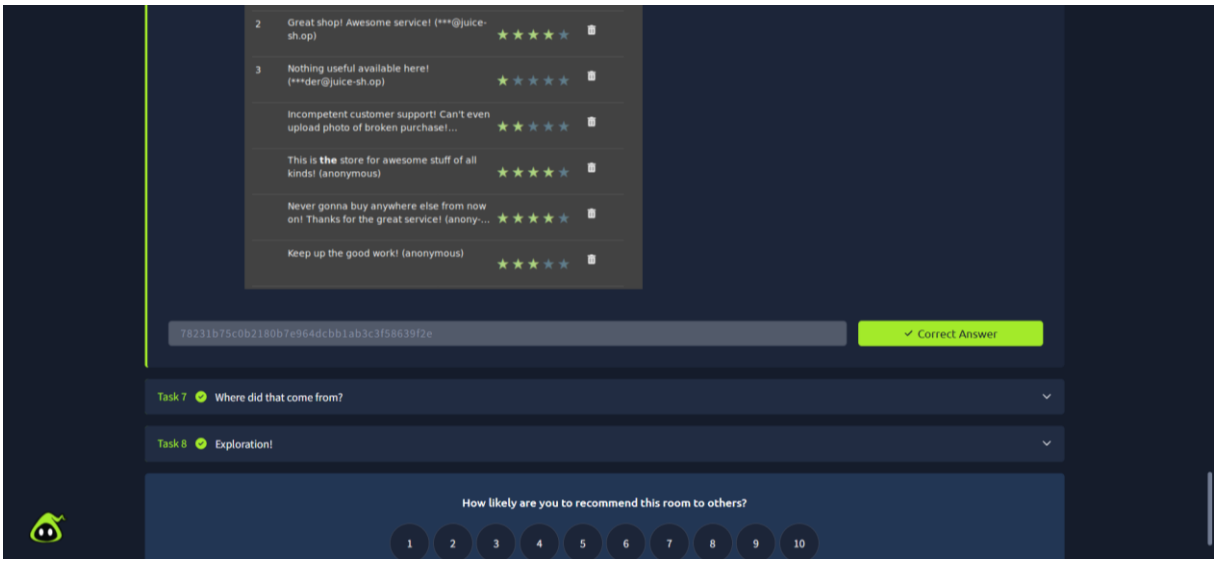

Show password advice
Change
3c3e2d6ef99b733b947e92f8e2a9ed08bf57ea63
✓ Correct Answer
Task 5 AH! Don't look!
Task 6 Who's flying this thing?
Task 7 Where did that come from?
Task 8 Exploration!
How likely are you to recommend this room to others?
1 2 3 4 5 6 7 8 9 10
Submit now

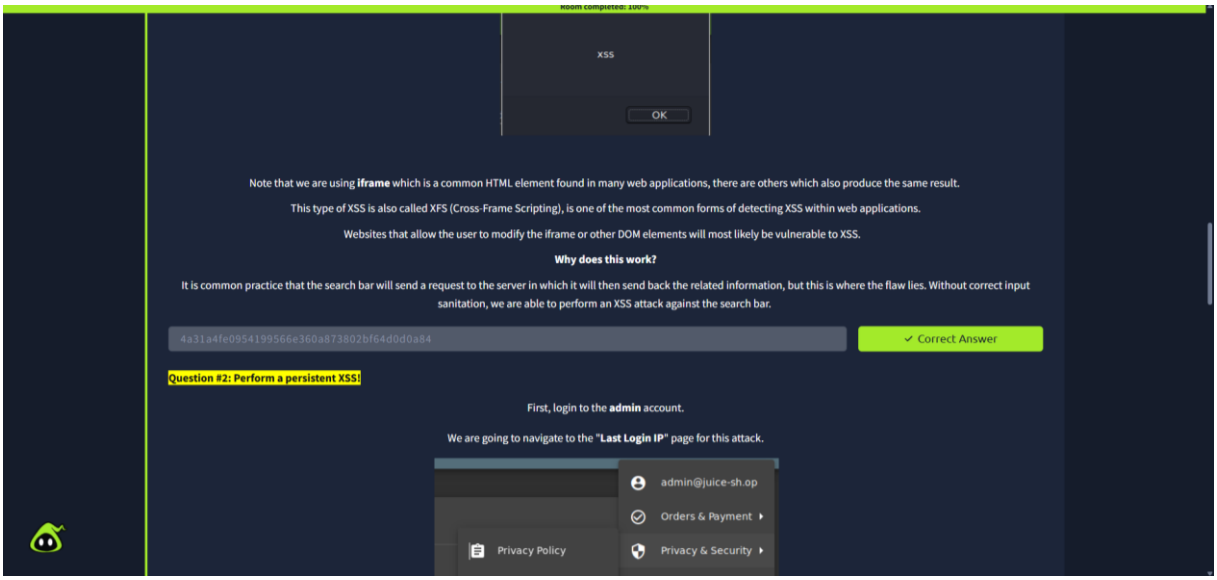

acquisitions.md and save it. It looks like there are other files of interest here as well.
After downloading it, navigate to the home page to receive the flag!
8d2072c6b0a455608ca1a293dc0c9579883fc6a5
✓ Correct Answer
Question #2: Log into MC SafeSearch's account!
Rapper Who Is Very Concerned With Password Security
Dropout
Watch on YouTube
After watching the video there are certain parts of the song that stand out.
He notes that his password is "Mr. Noodles" but he has replaced some "vowels into zeros", meaning that he just replaced the o's into 0's.
We now know the password to the mc.safesearch@juice-sh.op account is "Mr. N00dles"
bb105418e73708ceccf1a7b2491f434b8f5230e4
✓ Correct Answer
Question #3: Download the Backup file!

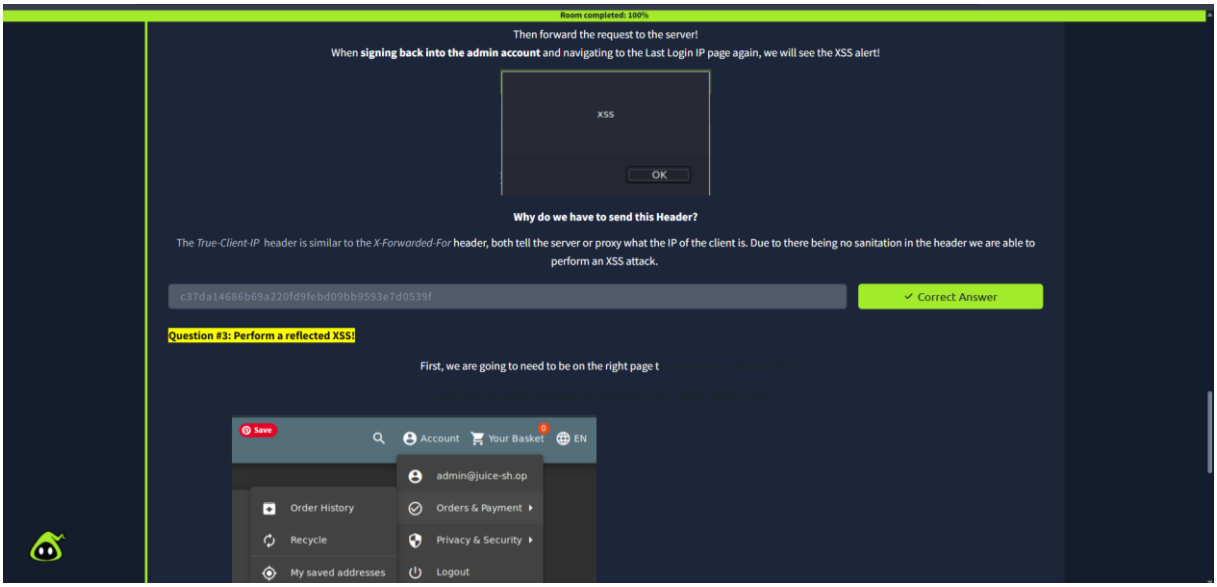

Room completed: 100%
OWASP Juice Shop (Express ^4.21.0)
403 Error: Only .md and .pdf files are allowed!
To get around this, we will use a character bypass called "Poison Null Byte". A Poison Null Byte looks like this: %00.
Note: as we can download it using the url, we will need to encode this into a url encoded format.
The Poison Null Byte will now look like this: %2500. Adding this and then a .md to the end will bypass the 403 error!
10.10.206.192/ftp/package.json.bak%2500.md
Why does this work?
A Poison Null Byte is actually a NULL terminator. By placing a NULL character in the string at a certain byte, the string will tell the server to terminate at that point, nulling the rest of the string.
cfdeea14e8f01b4952722fd0e4a77f1928593c9a
✓ Correct Answer
Task 6 Who's flying this thing?
Task 7 Where did that come from?

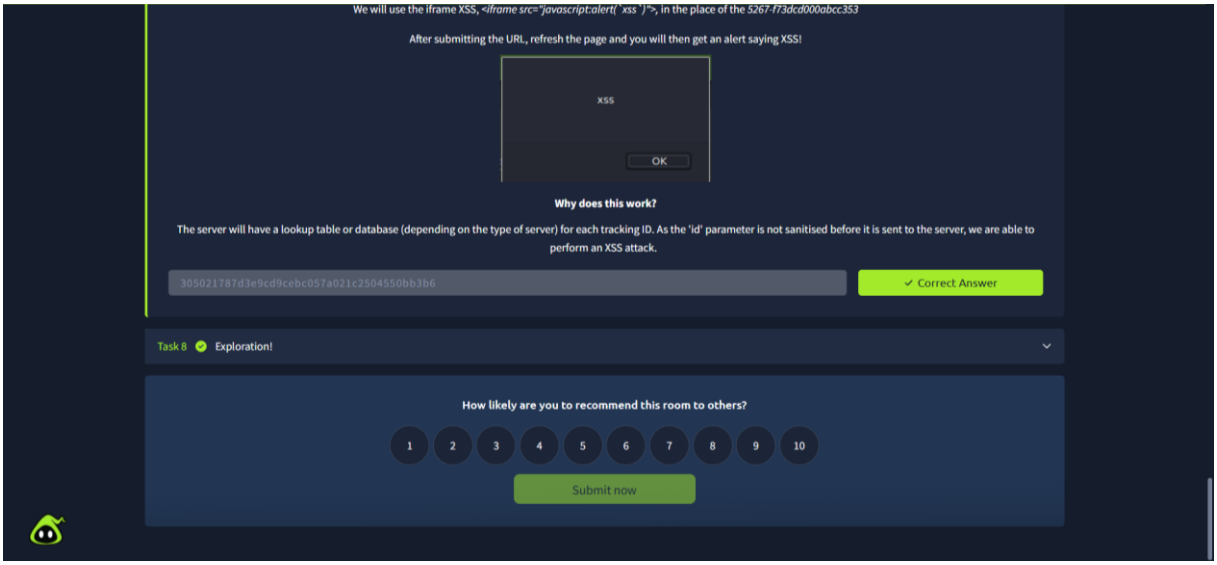

71aeb3b0bf01cc6e488f0207bb62f79b41454a87
✓ Correct Answer
Question #2: View another user's shopping basket!
Login to the Admin account and click on 'Your Basket'. Make sure Burp is running so you can capture the request!
Forward each request until you see: GET /rest/basket/1 HTTP/1.1
Now, we are going to change the number 1 after /basket/ to 2
GET /rest/basket/2 HTTP/1.1
It will now show you the basket of UserID 2. You can do this for other UserIDs as well, provided that they have one!
Your Basket (admin@juice-sh.op)

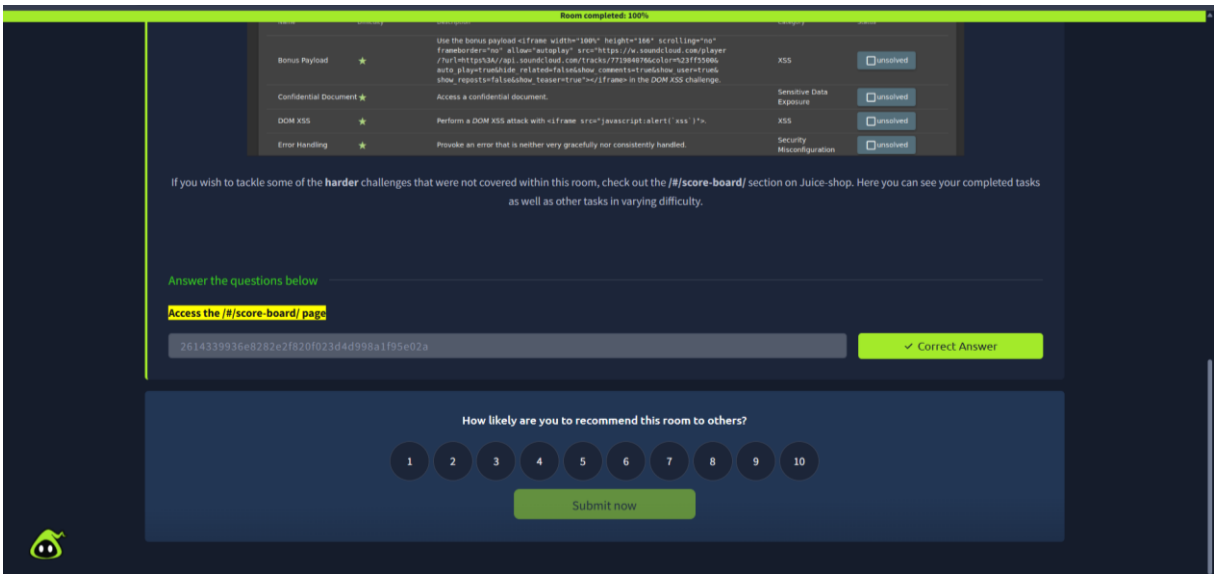

Raspberry Juice (1000ml) 2 4.99¤
Total Price: 9.98¤
Checkout
You will gain 0 Bonus Points from this order!
e6982b34b6734ceadd28e5019b251f929a80b815
✓ Correct Answer
Question #3: Remove all 5-star reviews!
Navigate to the http://MACHINE_IP/#/administration page again and click the bin icon next to the review with 5 stars!
Customer Feedback
1 I love this shop! Best products in town! Highly recommended! (***in@juice-sh.op)
2 Great shop! Awesome service! (***@juice-sh.op)
3 Nothing useful available here! (***der@juice-sh.op)
Incompetent customer support! Can't even upload photo of broken purchase!...


2 Great shop! Awesome service! (***@juice-sh.op)
3 Nothing useful available here! (***der@juice-sh.op)
Incompetent customer support! Can't even upload photo of broken purchase!...
This is the store for awesome stuff of all kinds! (anonymous)
Never gonna buy anywhere else from now on! Thanks for the great service! (anony-...
Keep up the good work! (anonymous)
78231b75c0b2180b7e964dcbb1ab3c3f58639f2e
✓ Correct Answer
Task 7 Where did that come from?
Task 8 Exploration!
How likely are you to recommend this room to others?
1 2 3 4 5 6 7 8 9 10


XSS
OK
Note that we are using iframe which is a common HTML element found in many web applications, there are others which also produce the same result.
This type of XSS is also called XFS (Cross-Frame Scripting), is one of the most common forms of detecting XSS within web applications.
Websites that allow the user to modify the iframe or other DOM elements will most likely be vulnerable to XSS.
Why does this work?
It is common practice that the search bar will send a request to the server in which it will then send back the related information, but this is where the flaw lies. Without correct input sanitation, we are able to perform an XSS attack against the search bar.
4a31a4fe0954199566e360a873802bf64d0d0a84
✓ Correct Answer
Question #2: Perform a persistent XSS!
First, login to the admin account.
We are going to navigate to the "Last Login IP" page for this attack.
admin@juice-sh.op
Orders & Payment
Privacy Policy
Privacy & Security


Room completed: 100%
Then forward the request to the server!
When signing back into the admin account and navigating to the Last Login IP page again, we will see the XSS alert!
xss
OK
Why do we have to send this Header?
The True-Client-IP header is similar to the X-Forwarded-For header, both tell the server or proxy what the IP of the client is. Due to there being no sanitation in the header we are able to perform an XSS attack.
c37da14686b69a220fd9febd09bb9593e7d0539f
✓ Correct Answer
Question #3: Perform a reflected XSS!
First, we are going to need to be on the right page t
Save
Account
Your Basket
EN
admin@juice-sh.op
Order History
Orders & Payment
Recycle
Privacy & Security
My saved addresses
Logout


We will use the iframe XSS, <iframe src="javascript:alert(`xss`)">, in the place of the 5267-f73dcd000abcc353
After submitting the URL, refresh the page and you will then get an alert saying XSS!
xss
OK
Why does this work?
The server will have a lookup table or database (depending on the type of server) for each tracking ID. As the 'id' parameter is not sanitised before it is sent to the server, we are able to perform an XSS attack.
30502178 7d3e9cd9cebc057a021c2504550bb3b6
✓ Correct Answer
Task 8 Exploration!
How likely are you to recommend this room to others?
1 2 3 4 5 6 7 8 9 10
Submit now



6. Impact

Depending on the vulnerabilities identified, successful exploitation in a real application may result in:

- **Unauthorized access:** Users may access restricted functionality or protected resources.
- **Sensitive information disclosure:** Confidential data, credentials, or application information may be exposed.
- **Data manipulation:** Weak access controls or injection flaws may allow unauthorized changes to data.
- **Client-side attacks:** XSS may allow attacker-controlled scripts to execute in a victim's browser.
- **Application compromise:** Certain vulnerabilities may provide a path to further exploitation.
- **Service disruption:** Some weaknesses may affect application availability or reliability.
- **Business and compliance risks:** Security incidents may result in financial loss, reputational damage, and regulatory consequences.

The actual impact and severity must be assessed according to the confirmed findings, affected functionality, privileges required, and evidence collected during testing.

7. Remediation

The following measures help improve web application security.

1. Use parameterized queries

Prevent SQL injection by using parameterized database queries instead of constructing queries through unsafe string concatenation.

2. Apply context-aware output encoding

Encode untrusted content appropriately before displaying it in HTML, JavaScript, or other contexts. Use safe templating practices to reduce XSS risks.

3. Enforce server-side authorization

Validate user permissions for every protected resource and sensitive action. Do not rely only on hidden links or client-side checks.

4. Implement secure authentication

Use secure session management, appropriate password storage, rate limiting, and additional protections where required.

5. Validate input server-side

Validate user input according to the expected format and business requirements. Treat client-side validation as a usability feature, not a security boundary.

6. Secure file handling

Restrict permitted file types, validate content, generate safe filenames, and prevent uploaded content from being executed unexpectedly.

7. Apply secure configuration

Disable unnecessary services and debug features, protect configuration files, and use secure defaults.

8. Protect sensitive information

Avoid exposing credentials, secrets, internal errors, or unnecessary sensitive data in application responses and logs.

9. Update dependencies

Maintain an inventory of application components and apply security updates to vulnerable libraries and frameworks.

10. Perform regular security testing

Use code reviews, automated testing, and authorized penetration testing to identify and remediate weaknesses before deployment.

8. What You Learned

The main learning outcomes of this lab are:

- Understanding the purpose of an intentionally vulnerable web application.
- Recognizing common web application security vulnerability categories.
- Reviewing authentication and authorization behavior.
- Understanding the importance of safe input handling and output encoding.
- Learning how to inspect application requests and responses.
- Understanding the security implications of misconfiguration and information exposure.
- Learning to record findings with reproducible evidence.
- Understanding how to recommend practical remediation measures.
- Recognizing the importance of verifying findings rather than assuming a vulnerability exists.

Update these learning outcomes according to the challenges and techniques you actually completed.

Conclusion

OWASP Juice Shop provides a practical environment for studying web application security and understanding how common implementation weaknesses can affect application confidentiality, integrity, and availability.

Effective web application security requires secure input handling, correct authorization, robust authentication, safe file processing, secure configuration, and regular testing.

This report provides a structured framework for documenting the OWASP Juice Shop exercise. The final assessment should reflect the challenges actually completed, the vulnerabilities confirmed, the supporting screenshots, and the recorded lab completion status.

Report Prepared By: Rohit Kushwah
Organization: IqraSec Academy
Internship: Web Application Penetration Testing (WAPT)